

VẤN ĐỀ 1: Reward Function (Hội đồng lo: AI chặn hết tất cả traffic)

Nhóm áp dụng cơ chế "Phạt Bất Đối Xứng" (Asymmetric Penalty) với logic như sau:

- Công thức (có thể vẫn sửa trong tương lai):
 - Điểm thưởng chặn đúng Attacker: +20
 - Điểm thưởng khi redirect Attacker qua HoneyPot: +30 (Cơ chế BAN leo thang, redirect ban đầu ít time, sau đó tăng time rồi tới block)
 - Điểm thưởng khi cho User qua: +5
 - Điểm phạt khi cho Attacker lọt qua: -50
 - Điểm phạt khi chặn nhầm User: -100
 - Điểm phạt khi redirect nhầm User qua HoneyPot: -10 (Có cơ chế time-to-live sẽ trả về lại trang chủ khi hết time)
- Trong các trường hợp AI chưa đạt độ tin cậy tuyệt đối, Agent sẽ được huấn luyện để ưu tiên hành động Redirect HoneyPot. Hành động này không làm ngắt kết nối của người dùng khi chặn nhầm nhưng vẫn vô hiệu hóa được Hacker.
- Giải quyết được vấn đề có thể gặp phải là AI sợ mất điểm nên không dám làm gì khi đó là Attacker thật nên có phần phạt để lọt Attacker qua trừ 50 để AI cũng sợ nếu đứng im không làm gì cũng chết.
- Nhóm dự kiến sẽ áp dụng việc dạy “leo thang”. Dạy đơn giản nhận dạng Attacker trước (giai đoạn này AI chặn sai nhiều, nhưng mục đích là cho nó chịu học), rồi nhóm mới siết điểm trừ cho nó cẩn thận hơn, cuối cùng là kỷ luật nặng theo thang điểm trừ cao

Kết luận: Việc AI Block tất cả là bất khả thi vì nó dẫn đến điểm thưởng âm.

VẤN ĐỀ 2: Feature Extraction (Hội đồng lo: Feature không ổn định AI không học được)

Nhóm đề xuất chiến lược trích xuất đặc trưng "Lai" (Hybrid Feature Extraction) gồm 2 lớp:

- **Lớp thống kê** (Statistical Layer): Sử dụng các chỉ số mạng cơ bản (Packet Rate, SYN Ratio, Port Variance) để phát hiện nhanh các tấn công đại trà như DDoS và Scanning.
- **Lớp Ngữ cảnh** (Context-Aware Layer): Đây là điểm mới để xử lý False Positive. Nhóm sẽ đưa thêm các "Cờ ngữ cảnh" (Context Flags) vào vector đầu vào. Ví dụ: Cờ is_upload_stream (dựa trên URL/Header) hoặc cờ error_response_rate (dựa trên phản hồi của Server).
- Vector đầu vào: $S = [f1, f2, f3, f4, f5, f6]$

	Tên đặc trưng	Mô tả & Logic trích xuất	Loại tấn công	Logic phát hiện
1	Tốc độ gói tin (Packet Rate)	Số lượng gói tin chuẩn hóa trên giây. Tính bằng cách đếm số gói tin đến từ một IP nguồn trong cửa sổ 1 giây.	DoS / DDoS (SYN Flood, UDP Flood)	User hợp lệ thường có tốc độ gửi gói tin thấp. Attacker buộc phải gửi lưu lượng lớn để làm nghẽn server, tạo ra sự gia tăng đột biến ở chỉ số này.
2	Tỷ lệ SYN/ACK (SYN/ACK Ratio)	Tỷ lệ giữa cờ SYN và cờ ACK. Công thức: Số gói SYN / (Số gói ACK + 1).	TCP Flood & Scanning (Quét lén)	Quá trình bắt tay TCP thông thường có tỷ lệ cân bằng (~1). Attacker thường gửi hàng loạt gói SYN mà không hoàn tất bắt tay (tỷ lệ >> 1) để quét cổng hoặc làm tràn tài nguyên.
3	Số cổng đích (Distinct Ports)	Số lượng cổng đích duy nhất. Đếm số cổng khác nhau mà một IP cố gắng kết nối tới trong một khoảng thời gian.	Port Scanning (Nmap, Masscan)	User bình thường chỉ truy cập 1-2 cổng (80/443). Kẻ tấn công quét hàng trăm cổng để tìm lỗ hổng, làm chỉ số này tăng vọt.
4	Độ dài tải trọng	Kích thước trung bình của phần dữ liệu gói tin.	SQL Injection / XSS	Các payload tấn công (ví dụ: câu lệnh SQL dài, mã script) thường dài hơn đáng kể so với dữ liệu

	(Payload Length)	Đo lường lượng dữ liệu được mang trong phần thân gói tin.	(Tấn công nội dung lớn)	nhập liệu thông thường (ví dụ: tên đăng nhập), tạo ra sự bất thường để phát hiện.
5	Tỷ lệ kết nối lỗi (Connection Fail Rate)	Tỷ lệ các lần thử kết nối thất bại. Tính bằng cách đếm phản hồi từ server có cờ RST hoặc mã lỗi HTTP 4xx/5xx.	Brute-Force & Fuzzing	User hợp lệ hiếm khi gây ra lỗi liên tục. Kẻ tấn công dò mật khẩu hoặc dò đường dẫn sẽ tạo ra tỷ lệ lỗi rất cao do sai thông tin hoặc đường dẫn không tồn tại.
6	Điểm ngữ cảnh (Context Score)	Điểm đánh giá dựa trên phân tích ngữ cảnh (Hybrid). +1.0 (Nguy hiểm): Payload chứa từ khóa (UNION, SELECT, <?php, eval). -0.5 (An toàn): URL chứa /upload VÀ payload không có từ khóa (Upload ảnh). 0.0: Trung tính.	Tấn công Web Nâng cao (Web Shell vs. Upload File)	Giảm False Positive: Đặc trưng giúp AI phân biệt giữa việc upload file hợp lệ kích thước lớn (Ngữ cảnh an toàn) và việc upload mã độc hoặc SQL injection, ngay cả khi cả hai đều có độ dài lớn.

VẤN ĐỀ 3: Hiệu năng phần cứng và Pipeline Real-time

Nhóm đã nâng Host Machine lên cấu hình: CPU Ryzen7 8845HS, GPU RTX 4050, RAM 36GB DDR5 5600.

Cách đề xuất để Pipeline Real-time như sau:

BATCH PROCESSING (gom lô)

Gom khoảng 100 hoặc 1000 dòng log vào RAM, sau đó mới mở file và ghi một lần. Giống xử lý bất đồng bộ (Asynchronous) nhưng đỡ hạn chế là đợi ghi nhiều lần rồi mới bắt đầu dọn 1 lượt.

Rủi ro: vẫn có thể mất dữ liệu trong RAM nếu bị sập.